

Staffbro — MVP Product Requirements Document

Version	1.2 — draft for founder review (name confirmed: Staffbro; team names corrected)
Date	18 September 2026
Product	Staffbro — two-sided hiring marketplace for frontline workers and hospitality / retail businesses in Pakistan
MVP market	Islamabad / Rawalpindi (twin cities)
Team	Muhammad Haris, Farhan Manzoor, Khizar Sheikh
Built from	<i>Project Idea Document</i> + the architecture review in Section 1
Audience	Founders, developers (turn into GitHub issues), NIC startup mentors

Priority legend — **P0**: pilot cannot launch without it · **P1**: ship if on schedule, otherwise first post-launch sprint · **P2**: designed-for, not built. **Requirement IDs** (e.g. `CAN-02`) are stable. Use them as GitHub issue titles and in commit messages.

Contents

1. Architecture review — what changed vs. the idea document
2. Product summary
3. Problem
4. Goals, non-goals, success criteria
5. Users and personas
6. Scope
7. Core product rules
8. Functional requirements
9. User flows
10. Data requirements
11. API surface (MVP, /api/v1)
12. Architecture summary
13. Security and privacy requirements
14. Product metrics and instrumentation
15. Non-functional requirements
16. Release plan
17. Team responsibilities
18. What not to build now — and how the MVP grows
19. Risks and mitigations
20. Assumptions and open decisions
- Appendix A — Glossary
- Appendix B — Sources for free-tier facts (read September 2026; verify before relying)
- Appendix C — Implementation notes for the backend

1. Architecture review — what changed vs. the idea document

The idea document's direction is sound: modular monolith, PostgreSQL, React Native + Expo, deterministic search, manual verification. The review below keeps all of that and fixes the places where the spec would hurt the pilot. Every change is reflected in the rest of this PRD.

#	Gap in the idea document	Decision in this PRD	Why
1	applications and direct_job_offers as two tables	One candidacies table with origin = APPLICATION \ DIRECT_OFFER , one state machine, append-only status events	Both flows stay first-class, but there is one pipeline to build, one funnel to measure, and one key (candidacy_id) that in-app chat can attach to later
2	Contact happens on phone/WhatsApp, so the funnel after "contact" is invisible	Log every contact tap; nudge both sides after 48 h; worker-confirmed hire	Without this, hiring rate, time-to-hire and interview rate (Section 14) cannot be measured, and the pilot cannot prove anything
3	Phone OTP assumed as part of "phone/email verification"	No SMS OTP in MVP . Phone is confirmed manually via a WhatsApp code ("reverse OTP") reviewed by admin	Phone-OTP is not free on realistic stacks (e.g. Firebase requires billing + per-SMS cost); workers are phone-first, often without email
4	Supabase Auth vs. FastAPI auth left ambiguous	FastAPI owns identity (phone + password, Argon2id, short JWT + rotating refresh). Supabase = managed Postgres + Storage only, accessed server-side	One authorization point, no RLS duplication, phone-first login, portable off Supabase
5	Free-tier operational gaps not addressed	Keep-alive ping, nightly encrypted pg_dump , staging on the 2nd free Supabase project, local Docker Postgres for dev	Supabase free pauses after 7 idle days and has no daily backups; Render free sleeps after 15 min
6	Business verification deferred to "future"	Manual business approval gate in MVP (admin call, then ACTIVE)	Cheap at pilot scale; the main protection against fake jobs and fee scams targeting workers
7	Worker PII exposure not specified	Phone never in list/search responses; revealed only inside a candidacy; area-level location only; first name + last initial until a candidacy exists; EXIF stripped	Safety (especially women workers), anti-disintermediation, data minimisation
8	CNIC handling described only as "protect it"	Image in private bucket, deleted at decision ; number never stored — only an HMAC for duplicate detection (optional)	Smallest possible liability surface
9	Distribution not addressed	Pilot ships as signed Android APK (WhatsApp/link); Play Store after pilot; iOS deferred	Expo Go is not a distribution channel; Play/AppStore accounts cost money and time
10	No growth loop	Shareable job link with WhatsApp preview page	Hiring already happens in WhatsApp groups — meet the behaviour instead of replacing it
11	Localisation framed as English/Urdu/Roman Urdu UI choices	i18n scaffolding from day 1; Roman Urdu is a search-alias layer , not a UI language; Urdu (RTL) UI is P1 pending decision D3	Roman Urdu has no standard spelling; aliases ("bawarchi", "rider") fix search without translation work
12	Notifications deferred wholesale	Minimal in-app inbox + Expo push is P1	Without chat, response latency decides success; push is free
13	Admin panel in Phase 6	Admin shell in Phase 2 (business approvals, phone confirmations)	Dependency order: approval gates job posting; the queue must exist before jobs do
14	Future-AI data collection mentioned, not specified	Structured job requirements, status events with reason codes, contact events, search/profile-view events from day 1	Labels for future matching cannot be back-filled
15	Direct-to-bucket uploads implied	Uploads go through the API (5 MB cap)	Server can verify file signatures, re-encode images, strip EXIF/GPS

2. Product summary

One-liner: Staffbro helps restaurants, hotels and grocery stores in Pakistan find and hire verified frontline workers — and helps workers get found — without leaving the WhatsApp/phone habits they already have.

Value proposition

For workers	For businesses
One profile instead of repeated WhatsApp forwards	Search by skill, area, experience, availability instead of asking around
See real jobs with pay, area, meals/accommodation	Verified badges reduce "unreliable hire" risk
Know where each application stands	One pipeline for applicants <i>and</i> headhunted workers
Get approached by employers without paying anyone	Post once, share the link into existing WhatsApp groups

Positioning: verified, structured, searchable hiring layered on top of WhatsApp — not a WhatsApp replacement.

3. Problem

Hiring for restaurants, hotels and grocery stores in Pakistan runs on WhatsApp groups, personal references, informal networks and scattered postings. Consequences: (1) employers cannot search, compare or verify candidates; (2) workers cannot discover openings beyond their network or prove their experience; (3) nobody tracks outcomes, so nothing improves. Staffbro replaces the scattered process with a structured, verifiable one.

4. Goals, non-goals, success criteria

Goals - **G1** Prove that businesses in Islamabad/Rawalpindi can fill frontline roles through Staffbro faster than through their current method. - **G2** Prove workers complete profiles and respond to opportunities at meaningful rates. - **G3** Establish a trusted supply base: manually verified phones, IDs and experience. - **G4** Collect clean funnel data that supports the next investment decision (and later AI matching).

Non-goals (MVP): in-app chat, AI matching, payments/subscriptions, automated KYC, payroll, ratings/reviews, multi-city, iOS release. See Section 18.

Pilot success criteria — starting hypotheses over an 8-week live pilot; calibrate them with Khizar's business interviews before launch.

Signal	Target
Approved (ACTIVE) businesses	≥ 25
Workers registered / profile-complete / phone-confirmed / ID-verified	400 / 250 / 150 / 75
Jobs posted	≥ 60
Median applications per job within 72 h	≥ 5
Median time to first candidate	≤ 24 h
Jobs with ≥ 1 worker-confirmed hire	≥ 30 % of closed jobs
Businesses posting a 2nd job within 30 days	≥ 40 %

5. Users and personas

Persona	Description	What they need	Key constraints
Worker — Bilal	24, waiter/cook/rider, Android phone (low-to-mid range), WhatsApp-first, limited English, may not use email	Find jobs nearby, show experience, get contacted, know status	Low data/storage, low literacy tolerance, privacy worries
Owner — Mrs. Rehman	Runs a café/grocery; hires a few times a year; decides pay	Fast, cheap candidates who will actually turn up	Time-poor; trusts references over apps
Manager — Kamran	Hotel/restaurant manager; hires continuously	Search, shortlist, track many candidates	May share access with co-managers
Admin — Staffbro ops	1–3 founders in the pilot	Approve businesses, confirm phones, review IDs quickly, remove bad actors	Everything is manual; needs a fast queue and safe document viewing

6. Scope

Area	P0	P1	P2 / later
Auth	Phone+password, refresh, admin-issued password reset, account deletion	Forgot-password automation	Email verification, OTP
Worker profile	Profile, skills, experience, photo, discoverability toggle	Offer opt-out, saved jobs	CV upload, CV parsing
Business	Create, admin approval, edit, public profile	Add managers, job limits	Business documents, branches
Jobs	Post / edit / close, search & filter, detail, contact buttons	Auto-expiry, share link, saved jobs	Boosting, templates
Discovery	Worker search & filters, profile view, deterministic ranking	Saved workers	Recommendations
Candidacy	Apply, direct offer, respond, review, status tracking, hire confirmation	Auto-expiry, nudges, bulk reject on fill	Interview scheduling
Verification	WhatsApp phone confirmation, ID review, badges	Experience verification	Automated KYC
Admin	Login, business queue, phone queue, ID queue, users/suspend, audit logging	Jobs, reports, metrics	Audit viewer, catalogue UI
Notifications	—	In-app inbox, Expo push	WhatsApp automation
Safety	ToS/privacy acceptance, suspension	Reports	Blocking
Localisation	i18n scaffolding, English, catalogue aliases	Urdu RTL	Roman Urdu input helpers

7. Core product rules

These rules are the "business logic contract". They are enforced in the service layer and covered by automated tests.

7.1 Identity and roles

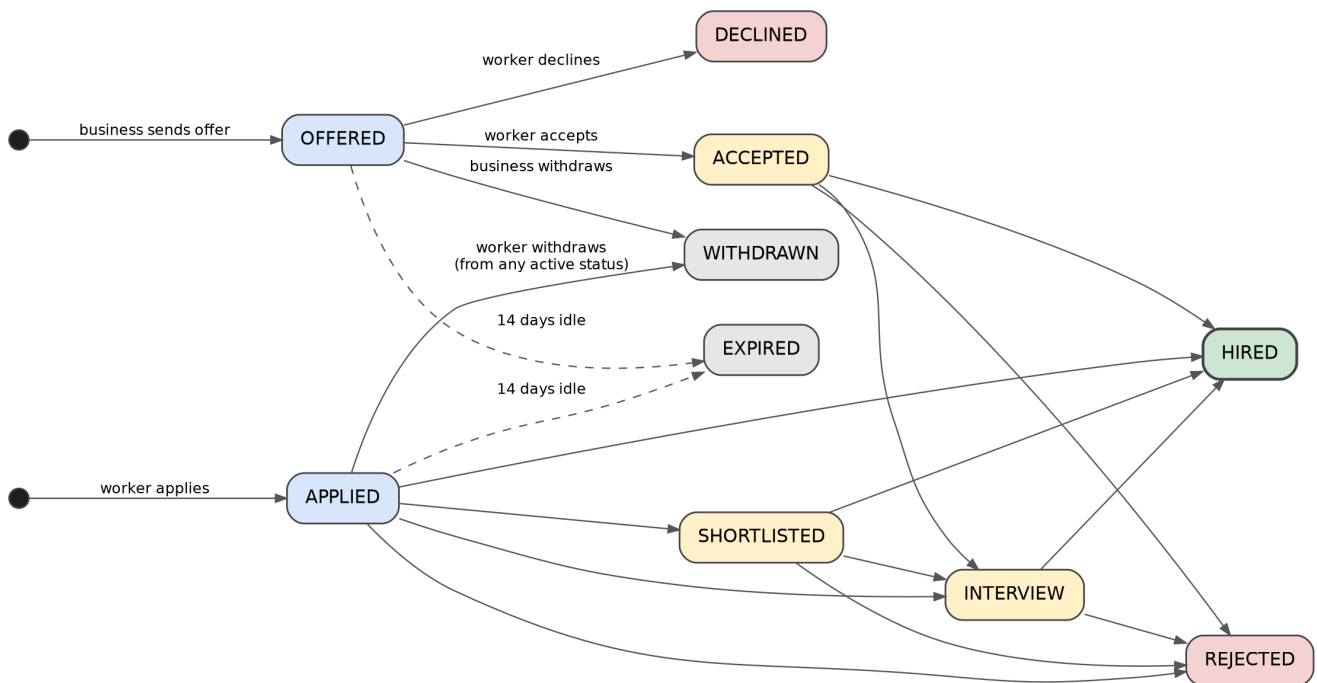
- One `users` table. One role per account at MVP: `WORKER`, `BUSINESS`, `ADMIN`. A person who both hires and seeks work uses two accounts.
- Login identifier is the **phone number**, normalised to E.164 (`03xx...` → `+923xx...`), unique.
- `BUSINESS` users act through `business_members` (`OWNER` or `MANAGER`). All business permissions are checked against membership, never against a user-level flag.
- `ADMIN` accounts are created by a seed script only — never via public registration.

7.2 The candidacy model (both flows, one pipeline)

A **candidacy** = one worker ↔ one job. `origin` records how it started.

	Flow A — worker applies	Flow B — business discovers
<code>origin</code>	<code>APPLICATION</code>	<code>DIRECT_OFFER</code>
Created by	Worker	Business member
Initial status	<code>APPLIED</code>	<code>OFFERED</code>
Requires	Job <code>OPEN</code> ; worker not suspended	Business <code>ACTIVE</code> ; worker discoverable & accepting offers; an <code>OPEN</code> job to offer for
Uniqueness	<code>UNIQUE(job_id, worker_id)</code> — one candidacy per worker per job, regardless of origin	same

If a business wants to approach a worker but has no matching job, the offer flow lets it create a job inline (`visibility = UNLISTED`, hidden from job search).



Candidacy state machine (both origins).

Transition permissions (single `POST /candidacies/:id/transition` endpoint validates against this table)

To status	Who may set it	Extra rules
<code>SHORTLISTED</code> , <code>INTERVIEW</code> , <code>HIRED</code> , <code>REJECTED</code>	Business member of the job's business	<code>REJECTED</code> requires a reason code (<code>NOT_QUALIFIED</code> , <code>POSITION_FILLED</code> , <code>NO_RESPONSE</code> , <code>PAY_MISMATCH</code> , <code>OTHER</code>). <code>HIRED</code> prompts worker confirmation
<code>ACCEPTED</code> , <code>DECLINED</code>	Worker	Only from <code>OFFERED</code> ; decline takes a reason code
<code>WITHDRAWN</code>	Worker (own application / accepted offer) or Business (own offer while <code>OFFERED</code>)	—
<code>EXPIRED</code>	System job	Scheduled trigger, Section 12.4

Every transition writes an immutable row to `candidacy_status_events` (from, to, actor, reason code, timestamp). Terminal statuses cannot be left. After `HIRED`, the worker can set `worker_confirmed_hire_at`.

7.3 Contact reveal rules

1. Worker phone/WhatsApp is **never** returned by list, search or profile-view endpoints.
2. It is returned only by `GET /candidacies/:id` to participants of that candidacy — i.e. after the worker applied, or after an `ACTIVE` business sent an offer.
3. Business phone/WhatsApp is published on the job and business page (the business chose to publish it), so workers can call before applying.
4. Every Call/WhatsApp tap posts a `contact_event` (channel, actor, candidacy or job).
5. Abuse limits: ≤ 15 new offers per business per day; ≤ 200 worker profile views per business per day; a declined offer cannot be re-sent for the same job.

7.4 Verification levels

Badge	Meaning	How it is granted (MVP)
Phone confirmed	The worker controls this WhatsApp number	Worker taps <i>Verify via WhatsApp</i> → app opens a <code>wa.me</code> chat to Staffbro's number with a prefilled code → admin sees the inbound message and confirms
ID verified	A human admin compared a CNIC image to the profile	Worker uploads CNIC front image (+ optional selfie) → <code>PENDING</code> → admin <code>VERIFIED</code> / <code>REJECTED</code>
Experience verified (per entry)	Admin phoned the reference on that job entry	Worker adds a private reference contact → admin calls → decision

A worker can **apply** without any badge, but becomes **discoverable** only when phone-confirmed. Changing the phone number clears the badge.

7.5 Job lifecycle

`OPEN` → `CLOSED` (`closed_reason`: `FILLED`, `NO_LONGER_NEEDED`, `EXPIRED`, `ADMIN_REMOVED`). No drafts in MVP. Jobs expire after 30 days unless renewed (P1). `visibility`: `PUBLIC` (searchable) or `UNLISTED` (reachable only via offer or direct link).

7.6 Business lifecycle

`PENDING_APPROVAL` → `ACTIVE` | `REJECTED`; `ACTIVE` ↔ `SUSPENDED`. Only `ACTIVE` businesses can post jobs, search workers or send offers.

7.7 Who sees what

Worker data	Business browsing (no candidacy)	Business with candidacy	Admin
First name + last initial	✓	full name	✓
Photo (optional)	✓	✓	✓
Profession, skills, experience (title, employer, duration), expected salary, availability	✓	✓	✓
Area / locality (never coordinates)	✓	✓	✓
Phone / WhatsApp	✗	✓	✓
Experience reference contacts	✗	✗	✓
CNIC image	✗	✗	only during review, via 60-second signed URL
Verification badges	✓	✓	✓

8. Functional requirements

Format: **ID • Requirement • Priority • Acceptance criteria (AC)**. Each row is issue-sized or splits cleanly into issues.

8.1 Authentication and accounts (AUTH)

ID	Requirement	P	Acceptance criteria
AUTH-01	Register with phone, password, full name, role (WORKER / BUSINESS) and accept ToS + privacy policy	P0	Phone normalised to E.164; duplicate → 409 PHONE_TAKEN ; password ≥ 8 chars; ToS version + timestamp stored
AUTH-02	Login with phone + password → access token (15 min) + refresh token (30 days)	P0	Wrong credentials → generic 401 ; 5 failures / 15 min per phone+IP → 429 ; suspended → 403 ACCOUNT_SUSPENDED
AUTH-03	Refresh with rotation and reuse detection	P0	Reusing an old refresh token revokes the whole token family
AUTH-04	Logout revokes the refresh token	P0	Token unusable afterwards
AUTH-05	Password reset via admin-issued one-time code (delivered by admin over WhatsApp)	P0	Code hashed, 1 h expiry, single use; all sessions revoked on reset
AUTH-06	Change password in-app	P0	Requires current password; revokes other sessions
AUTH-07	Delete my account	P0	Profile PII removed/anonymised, documents deleted, counterpart history shows "Deleted user"; see Section 13.4
AUTH-08	Optional email field (unverified)	P2	Not used for login in MVP

8.2 Worker profile (WRK)

ID	Requirement	P	AC
WRK-01	Create/edit profile: primary profession, area, expected salary (PKR, monthly range), availability (IMMEDIATE , WITHIN_2_WEEKS , NOT_LOOKING), commute scope (AREA_ONLY , CITY , TWIN_CITIES), employment types wanted, bio ≤ 300 chars	P0	Server-side validation; profession & area must exist in catalogue
WRK-02	Pick skills from catalogue (max 15)	P0	Unknown skill IDs rejected; skills can belong to any profession
WRK-03	Add/edit/delete experience (title, employer, start/end or <i>current</i> , description, optional private reference name+phone)	P0	End ≥ start; reference contact never appears in any non-admin response
WRK-04	Upload profile photo	P0	Section 13.3 rules; re-encoded ≤ 512 px, EXIF stripped; stored in public avatar bucket under a random UUID path
WRK-05	Profile completeness meter (photo, profession, ≥ 3 skills, ≥ 1 experience, area, salary, availability)	P0	Recomputed server-side on each save
WRK-06	"Show me to businesses" toggle	P0	Discoverable ⇔ toggle on ∧ phone confirmed ∧ profession ∧ area ∧ availability ≠ NOT_LOOKING
WRK-07	"Accept direct offers" toggle	P1	Off → cannot receive new offers
WRK-08	CV upload (PDF)	P2	Profile is the CV for this segment
WRK-09	Saved jobs	P1	Idempotent save/unsave

8.3 Business (BIZ)

ID	Requirement	P	AC
BIZ-01	Create business: type (RESTAURANT / HOTEL / GROCERY), name, area + address text, description ≤ 500, contact phone, WhatsApp number	P0	Creator becomes OWNER ; status PENDING_APPROVAL
BIZ-02	Pending state UX	P0	Pending business sees "awaiting approval"; post/search/offer endpoints return 403 BUSINESS_NOT_ACTIVE
BIZ-03	Edit business profile	P0	Owner/manager only; edits to name/phone logged in audit_logs
BIZ-04	Add/remove managers (by phone, must be a BUSINESS user)	P1	Only OWNER ; cannot remove last owner
BIZ-05	Business page visible to workers (name, type, area, description, approved badge, contact)	P0	Only ACTIVE businesses visible

8.4 Jobs (JOB)

ID	Requirement	P	AC
JOB-01	Post job: title, profession, required/preferred skills, employment type (FULL_TIME , PART_TIME , DAILY_WAGE), pay type + PKR range, area, positions, min experience, description ≤ 1000, provides meals / accommodation, optional start-by date	P0	Salary min ≤ max; business ACTIVE ; max 10 open jobs per business (P1 limit)
JOB-02	Edit an OPEN job	P0	Members of the owning business only; other businesses → 403
JOB-03	Close job with reason	P0	Pending candidacies remain visible; affected workers notified (P1)
JOB-04	Auto-expire after 30 days with renewal	P1	Scheduled trigger
JOB-05	Search/filter jobs: profession, skills, area/city, min salary, employment type, meals/accommodation, text	P0	Keyset pagination, 20/page; default sort newest; text matches title + profession/skill aliases (incl. Roman Urdu)
JOB-06	Job detail with business info and Call / WhatsApp buttons	P0	Taps log contact_event (job-level when no candidacy)
JOB-07	Share job to WhatsApp via link with preview page	P1	Public page /j/:slug returns Open Graph tags + "Open in app / Download APK"; no worker data
JOB-08	Business sees its jobs with applicant counts	P0	Counts scoped to own jobs

8.5 Worker discovery (DSC)

ID	Requirement	P	AC
DSC-01	Search workers: profession, skills (any/all), area/city (respecting commute scope), experience range, expected salary max, availability, verification badges	P0	Only discoverable workers; only ACTIVE businesses
DSC-02	Deterministic ranking: verified badges → completeness → recent activity	P0	Same query = same order; documented in code and this PRD
DSC-03	Worker card + profile view per Section 7.7	P0	No phone, no reference contacts, no coordinates in payload
DSC-04	Saved workers (shortlist)	P1	Per business, shared by its members
DSC-05	Rate limits per Section 7.3	P0	429 with code VIEW_LIMIT

ID	Requirement	P	AC
DSC-06	Log <code>search_events</code> (filters, result count) and <code>profile_view_events</code>	P1	No UI; write-only, needed for future ranking

8.6 Candidacies: applications and direct offers (`CAN`)

ID	Requirement	P	AC
CAN-01	Worker applies to an <code>OPEN</code> , <code>PUBLIC</code> job with optional note ≤ 200 chars	P0	Duplicate → <code>409 ALREADY_CANDIDATE</code> ; creates <code>APPLIED</code> + status event; business notified (P1)
CAN-02	Business sends a direct offer for one of its <code>OPEN</code> jobs to a discoverable worker (message ≤ 300 chars)	P0	Creates <code>OFFERED</code> ; worker phone revealed to this business inside the candidacy; limits per 7.3
CAN-03	Worker accepts/declines an offer	P0	Only from <code>OFFERED</code> ; decline reason code
CAN-04	Business lists candidacies per job, filter by status/origin	P0	Only own jobs; other business → <code>404</code> (not <code>403</code> , to avoid probing)
CAN-05	Business changes status per 7.2	P0	Invalid transition → <code>422 INVALID_TRANSITION</code> with allowed set
CAN-06	Worker sees all own candidacies with status timeline	P0	Both origins in one list
CAN-07	Worker withdraws	P0	Allowed from any non-terminal status
CAN-08	Hire confirmation: worker confirms after <code>HIRED</code>	P0	Sets <code>worker_confirmed_hire_at</code> ; unconfirmed after 7 days shown as "unconfirmed" in metrics
CAN-09	Auto-expire idle <code>APPLIED</code> / <code>OFFERED</code> after 14 days	P1	Writes <code>EXPIRED</code> event
CAN-10	Nudge 48 h after first contact tap or any idle candidacy: "Did you interview/hire?"	P1	One nudge per candidacy per status
CAN-11	On <code>HIRED</code> filling the last position → prompt to close job and bulk-reject pending with <code>POSITION_FILLED</code>	P1	One-tap bulk action

8.7 Contact (`CON`)

ID	Requirement	P	AC
CON-01	Call (<code>tel:</code>) and WhatsApp (<code>https://wa.me/<digits>?text=...</code>) buttons wherever 7.3 allows	P0	Prefilled WhatsApp text includes job title and Staffbro name
CON-02	Log every tap	P0	<code>POST /candidacies/:id/contact-events</code> (or job-level)
CON-03	Numbers stored and returned in E.164	P0	Validated on write
CON-04	Messaging hook only	—	No message tables in MVP; <code>candidacy_id</code> is the future conversation key

8.8 Verification (`VER`)

ID	Requirement	P	AC
VER-01	Phone confirmation via WhatsApp code	P0	Request creates <code>PENDING</code> row with one-time code (24 h validity); admin confirms/rejects
VER-02	ID verification submission	P0	CNIC front image (+ optional selfie) uploaded to private bucket; optional CNIC number typed by worker is HMAC'd and discarded (never stored in plain text)
VER-03	Admin decision <code>VERIFIED</code> / <code>REJECTED</code> with reason code	P0	Image hard-deleted at decision; failsafe job deletes anything older than 14 days
VER-04	Experience verification per entry	P1	Admin records call outcome; badge per entry + count on profile

ID	Requirement	P	AC
VER-05	Badges displayed	P0	Badge data only; no CNIC data ever displayed to businesses
VER-06	Resubmission limit	P1	Max 3 attempts / 30 days per type
VER-07	Phone change clears phone badge	P1	Re-confirmation required

8.9 Admin (ADM) — web app

ID	Requirement	P	Phase
ADM-01	Login for <code>ADMIN</code> role; seed-created accounts; extra login rate limits	P0	2
ADM-02	Business approval queue: view details, approve/reject with reason	P0	2
ADM-03	Phone-confirmation queue (phone, code, requested time, confirm/reject)	P0	2
ADM-04	ID verification queue with 60-second signed image URL; decision form	P0	5
ADM-05	Users list/search; suspend/unsuspend; issue password-reset code	P0	2
ADM-06	Jobs list; remove job	P1	6
ADM-07	Reports queue; resolve/dismiss	P1	6
ADM-08	Metrics dashboard (Section 14) backed by SQL views	P1	6
ADM-09	Every admin decision and every document view written to <code>audit_logs</code>	P0	2 onward
ADM-10	Catalogue management UI (professions, skills, areas)	P2	— (seed + SQL in pilot)

8.10 Notifications (NTF)

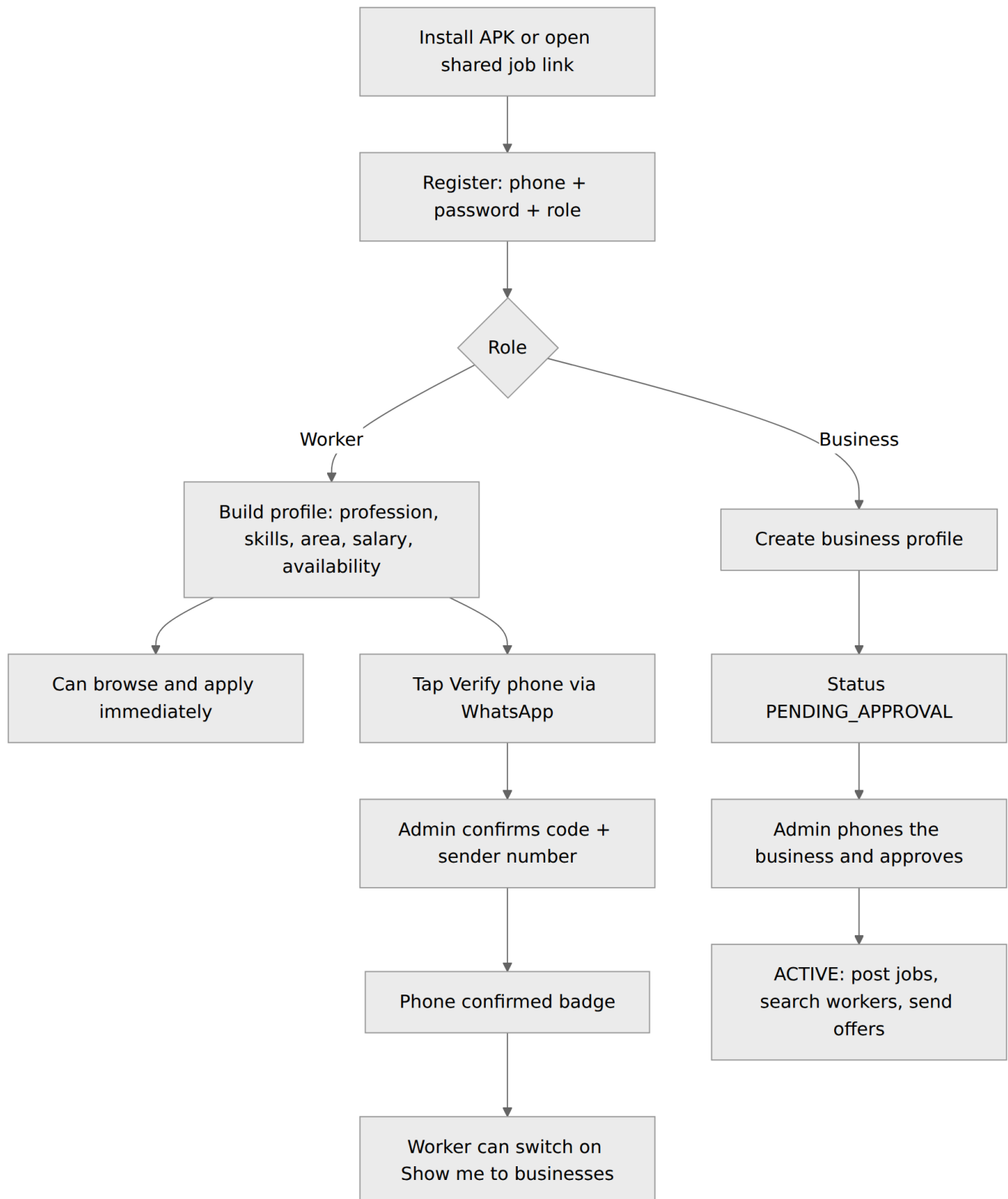
ID	Requirement	P	AC
NTF-01	In-app inbox (<code>notifications</code> table)	P1	Read/unread; deep-links to the candidacy/job
NTF-02	Expo push for: new application, new offer, status change, hire-confirmation request, verification decision	P1	Best-effort; failure never breaks the API call
NTF-03	Device token registration	P1	Token unique per device; stale tokens pruned
NTF-04	SMS / email / automated WhatsApp	—	Out of scope

8.11 Safety, legal, localisation (SAF , LOC)

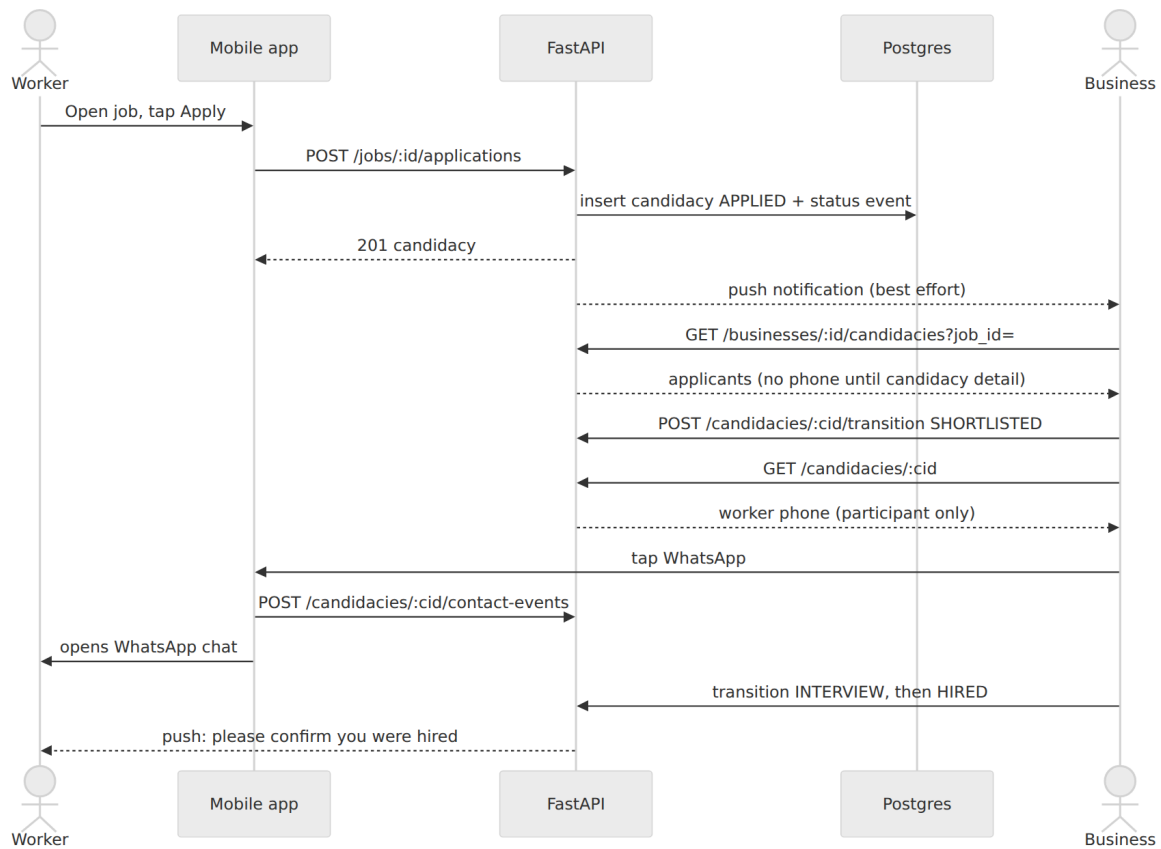
ID	Requirement	P	AC
SAF-01	Suspension takes effect immediately	P0	Auth dependency loads user status on every request
SAF-02	Report a user, business, job or candidacy	P1	Reason code + details $\leq$ 500; appears in admin queue
SAF-03	ToS states: Staffbro never charges workers; jobs asking workers for money are removed	P0	Shown at signup; reportable
LOC-01	All UI strings from <code>i18n</code> resource files	P0	Zero hard-coded user-facing strings
LOC-02	English UI at launch	P0	—
LOC-03	Urdu UI (RTL)	P1	Pending decision D3
LOC-04	Catalogues carry <code>name_en</code> , <code>name_ur</code> , <code>aliases[]</code> (includes Roman Urdu spellings)	P0	Job/worker text search hits aliases

9. User flows

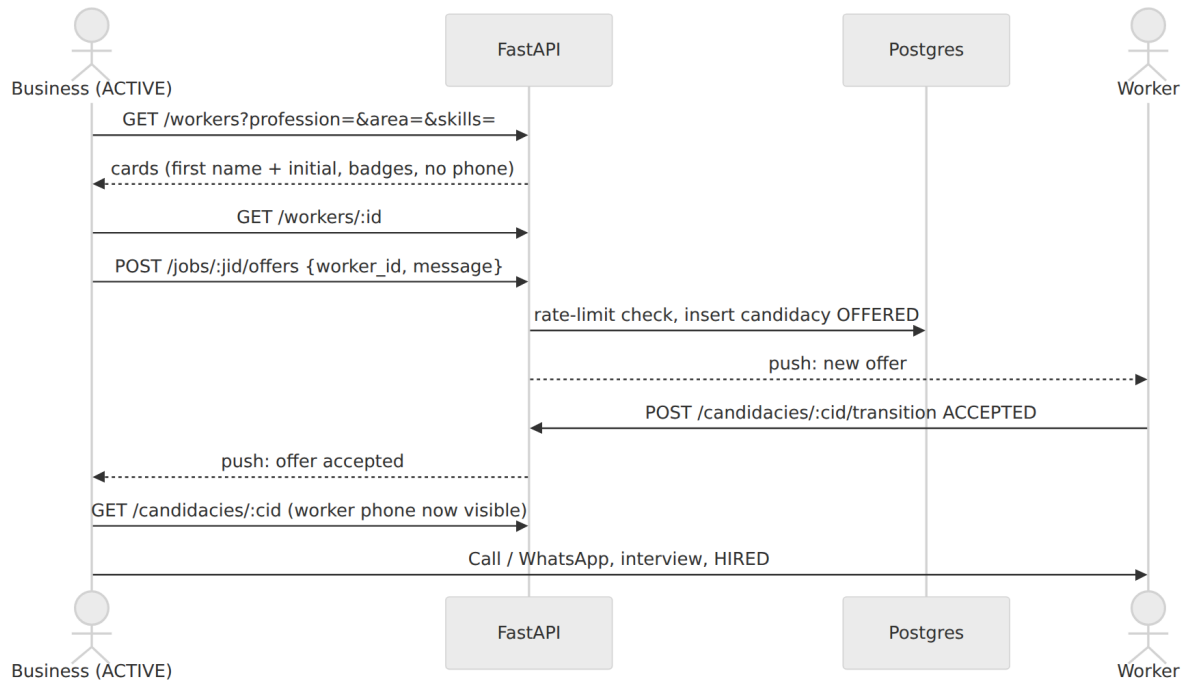
9.1 Registration and gating (worker and business)



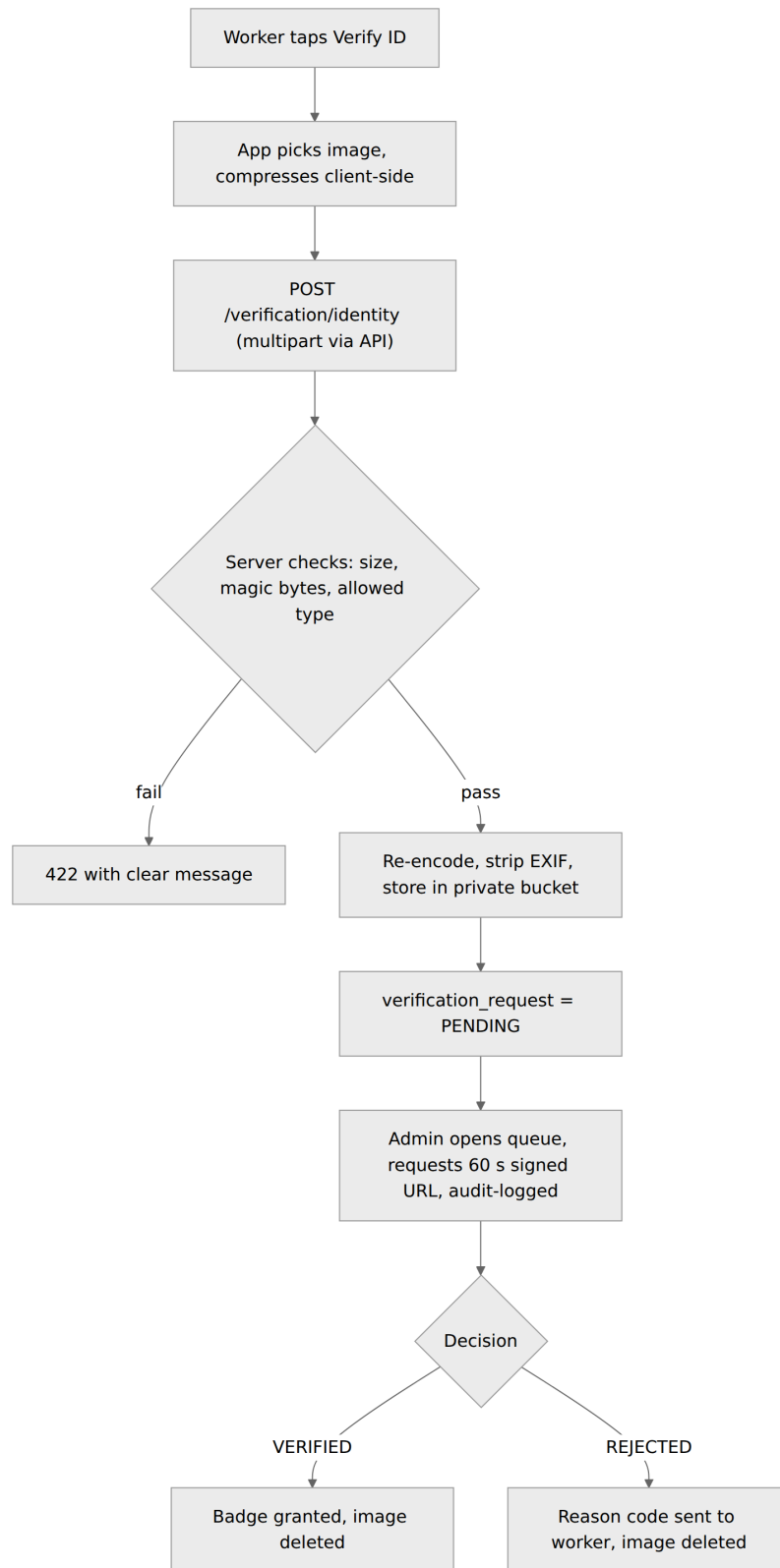
9.2 Flow A — worker applies



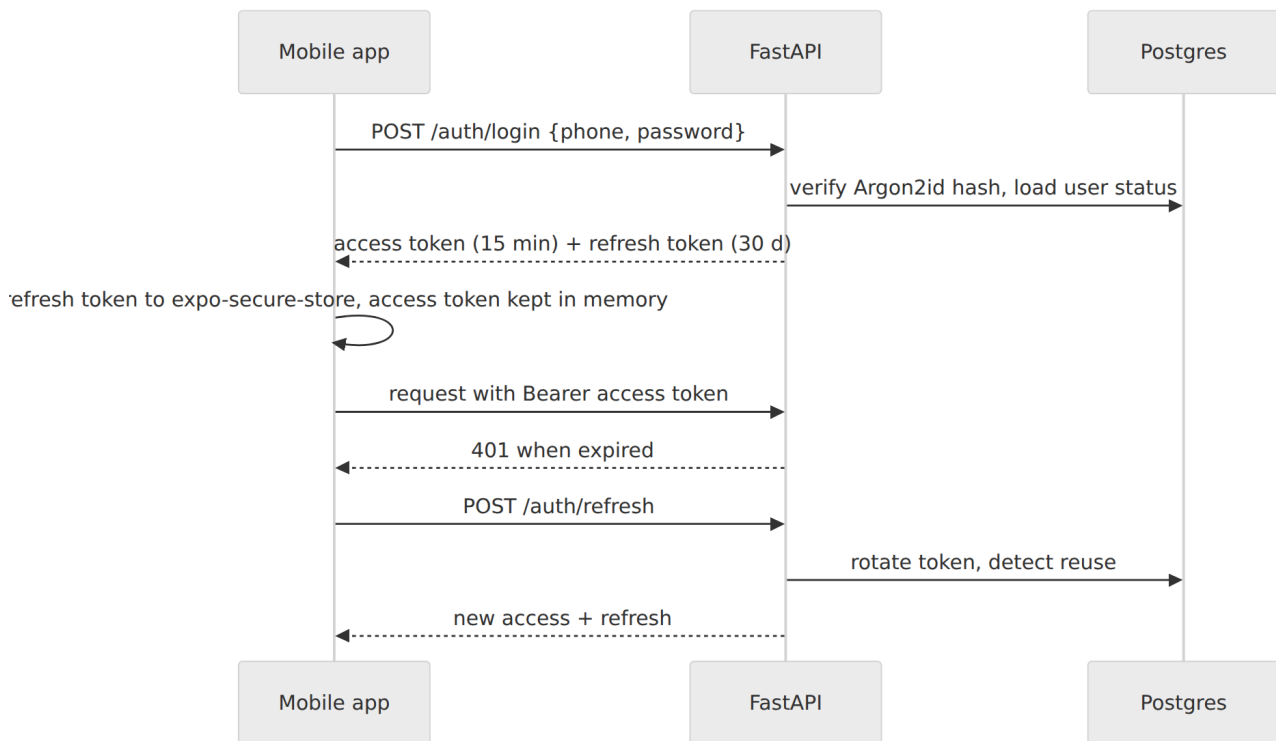
9.3 Flow B — business discovers and offers



9.4 Verification and file upload



9.5 Authentication



10. Data requirements

10.1 Entities

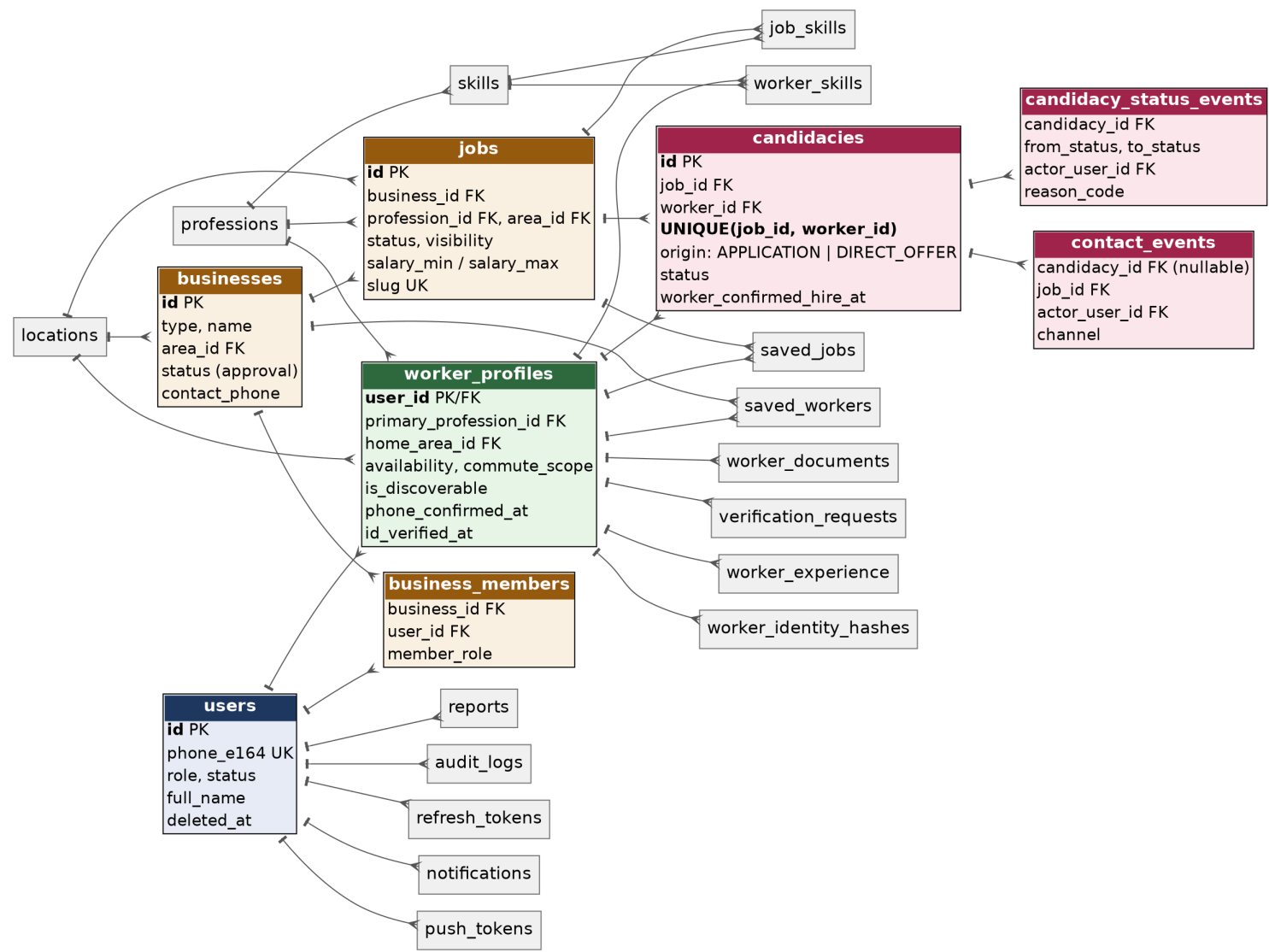
Conventions: UUID primary keys (`gen_random_uuid()`), `created_at` / `updated_at` on every table, enums as Postgres `ENUM` or `CHECK` -constrained text, money as integer PKR, all foreign keys indexed.

Table	Purpose	Key fields	Constraints / indexes	Soft delete
users	Single identity for all roles	phone_e164, password_hash, role, status (ACTIVE / SUSPENDED / DELETED), full_name, tos_version, tos_accepted_at, optional email, reset-code hash + expiry	UNIQUE(phone_e164); index (role, status)	deleted_at + anonymisation
refresh_tokens	Rotating sessions	user_id, token_hash, family_id, expires_at, revoked_at, device_info	UNIQUE(token_hash); index (user_id)	Purged after expiry
locations	Country → province → city → area tree	parent_id, level, name_en, name_ur, slug, optional lat / lng	UNIQUE(parent_id, slug); index (parent_id)	is_active
professions	Worker/job categories	slug, name_en, name_ur, aliases text[], is_active	UNIQUE(slug); GIN on aliases	is_active
skills	Controlled skill vocabulary	profession_id (nullable), slug, name_en, name_ur, aliases text[]	UNIQUE(slug); GIN on aliases	is_active
worker_profiles	1:1 with WORKER user	user_id (PK/FK), primary_profession_id, home_area_id, commute_scope, expected_salary_min/max, availability, employment_types[], bio, photo_path, is_discoverable, accepts_offers, completeness, total_experience_months, phone_confirmed_at, id_verified_at, last_active_at	Indexes: (is_discoverable, primary_profession_id, home_area_id), (availability), (total_experience_months)	Follows user
worker_skills	Worker ↔ skill	worker_id, skill_id, optional years	PK (worker_id, skill_id); index (skill_id)	Hard delete
worker_experience	Work history	worker_id, title, employer_name, profession_id, start_date, end_date, is_current, description, private reference_name, reference_phone, verified_at	CHECK(end_date IS NULL OR end_date >= start_date); index (worker_id)	Hard delete
worker_documents	Uploaded files (photo, CV, ID, selfie)	worker_id, doc_type, bucket, storage_path, mime, size_bytes, status, delete_after	Index (worker_id, doc_type); ID docs carry delete_after	status = DELETED after purge
worker_identity_hashes	Duplicate-ID detection, isolated	worker_id, cnic_hmac	UNIQUE(cnic_hmac); app role with narrowest access	Deleted with account
verification_requests	Manual verification queue + history	worker_id, type (PHONE / IDENTITY / EXPERIENCE), status (PENDING / VERIFIED / REJECTED / CANCELLED), document_id, experience_id, code_hash, reviewed_by, reviewed_at, reason_code, admin_note	Partial unique: one PENDING per (worker_id, type) (per experience for EXPERIENCE); index (status, type, created_at)	Never deleted (audit)
businesses	Business profile	type, name, area_id, address_text, description, contact_phone, whatsapp_phone, optional lat / lng, status, approved_by, approved_at	Index (status), (area_id)	deleted_at
business_members	Users acting for a business	business_id, user_id, member_role (OWNER / MANAGER), status	UNIQUE(business_id, user_id); index (user_id)	status = REMOVED

Table	Purpose	Key fields	Constraints / indexes	Soft delete
jobs	Job postings	business_id, created_by, title, profession_id, employment_type, pay_type, salary_min/max, area_id, positions_count, min_experience_months, description, provides_meals, provides_accommodation, start_by, status, closed_reason, visibility, slug, expires_at	CHECK(salary_min <= salary_max); indexes (status,visibility,profession_id,area_id,created_at DESC), (business_id,status); UNIQUE(slug)	deleted_at (admin removal)
job_skills	Job ↔ skill	job_id, skill_id, is_required	PK (job_id, skill_id)	Hard delete
candidacies	Application or direct offer	job_id, worker_id, origin, initiated_by_user_id, status, note, offer_message, worker_confirmed_hire_at, decided_at	UNIQUE(job_id, worker_id) ; indexes (job_id,status), (worker_id,status)	Never deleted; anonymised on account deletion
candidacy_status_events	Append-only history	candidacy_id, from_status, to_status, actor_user_id, reason_code, note	Index (candidacy_id,created_at); insert-only	Never
contact_events	Call/WhatsApp taps	candidacy_id (nullable), job_id, actor_user_id, channel	Index (candidacy_id), (job_id)	Never
saved_workers / saved_jobs	Shortlists / bookmarks	business_id + worker_id / worker_id + job_id	Composite PKs	Hard delete
notifications	In-app inbox	user_id, type, candidacy_id, payload jsonb, read_at	Index (user_id,read_at,created_at DESC)	Purged after 90 days
push_tokens	Expo push tokens	user_id, token, platform, last_seen_at	UNIQUE(token)	Hard delete
reports	Abuse reports	reporter_user_id, target_type, target_id, reason_code, details, status, handled_by	Index (status,created_at)	Never
audit_logs	Security-relevant actions	actor_user_id, action, entity_type, entity_id, metadata jsonb, ip, created_at	Insert-only; no PII in metadata	Never
search_events, profile_view_events	Future-ranking data	actor, filters/target, counts, timestamps	Insert-only; retain 12 months	Pruned

Why these extra tables vs. the idea document: candidacies + candidacy_status_events replace applications + direct_job_offers; contact_events and worker_identity_hashes support the funnel and privacy requirements; locations, professions and refresh_tokens are prerequisites of search and self-owned auth. favorites is justified as two tiny tables; notifications is justified by CAN-10/NTF-01.

10.2 ERD



Entity-relationship diagram. Key fields shown; full field lists are in Section 10.1.

10.3 Location model

- `locations` is a tree: `COUNTRY` → `PROVINCE` → `CITY` → `AREA` , seeded for Pakistan with full depth only for Islamabad and Rawalpindi.
- Workers store `home_area_id` + `commute_scope` . Businesses and jobs store `area_id` plus optional `lat / lng` (public places only). **Workers never store coordinates in MVP.**
- Search: same area → same city → twin-city (Islamabad U Rawalpindi), driven by `commute_scope` . Pure SQL joins on IDs.
- **Not in MVP:** PostGIS, geocoding APIs, distance sorting. **Upgrade path:** add a `geography(Point)` column (PostGIS is available on Supabase), backfill from area centroids, add GiST index, expose `distance_km` — no schema redesign.

10.4 Data retention

Data	Retention
CNIC image / selfie	Deleted at decision; failsafe purge at 14 days
CNIC HMAC	Life of account
Profile photo	Life of account
Candidacy + status events + contact events	Kept for metrics; anonymised (worker/business names removed) on account deletion
Notifications	90 days
Refresh tokens	Until expiry, then purged
Audit logs	12 months minimum
Search / view events	12 months
Deleted accounts	PII removed immediately; nightly backups age out within 30 days

11. API surface (MVP, `/api/v1`)

Conventions: JSON over HTTPS; Authorization: Bearer `<access token>` ; errors use one envelope `{ "error": { "code": "...", "message": "...", "details": [...] } }` ; list endpoints use keyset pagination (`?limit=20&cursor=...` → `{ items, next_cursor }`); POST create endpoints that may be retried accept an Idempotency-Key header (P1). The full request/response spec is generated from FastAPI's OpenAPI schema and TypeScript client types are generated from it (`openapi-typescript`), so mobile and backend share one contract.

Group	Method + path	Role	Purpose
Auth	POST <code>/auth/register</code>	public	AUTH-01
	POST <code>/auth/login</code> , <code>/auth/refresh</code> , <code>/auth/logout</code>	public / any	AUTH-02..04
	POST <code>/auth/change-password</code> , <code>/auth/reset-password</code>	any / public	AUTH-05/06
	GET/PATCH/DELETE <code>/me</code>	any	Own account, AUTH-07
Catalogue	GET <code>/catalog/professions</code> , <code>/catalog/skills</code> , <code>/catalog/locations</code>	any	Cached reference data
Workers	GET/PATCH <code>/workers/me</code>	worker	WRK-01, 05, 06, 07
	PUT <code>/workers/me/skills</code>	worker	WRK-02
	POST/PATCH/DELETE <code>/workers/me/experience[:id]</code>	worker	WRK-03
	POST/DELETE <code>/workers/me/photo</code>	worker	WRK-04

Group	Method + path	Role	Purpose
	GET /workers	business (active)	DSC-01/02
	GET /workers/:id	business (active)	DSC-03
	GET/PUT/DELETE /workers/me/saved-jobs[:job_id]	worker	WRK-09
Businesses	POST /businesses	business	BIZ-01
	GET /businesses/mine, GET/PATCH /businesses/:id	member / worker (read, active only)	BIZ-03/05
	GET/POST/DELETE /businesses/:id/members	owner	BIZ-04
	GET/PUT/DELETE /businesses/:id/saved-workers[:worker_id]	member	DSC-04
Jobs	GET /jobs, GET /jobs/:id	worker	JOB-05/06
	POST /businesses/:id/jobs	member (active)	JOB-01
	PATCH /jobs/:id, POST /jobs/:id/close, POST /jobs/:id/renew	member	JOB-02..04
	GET /businesses/:id/jobs	member	JOB-08
	GET /public/jobs/:slug and web page /j/:slug	public	JOB-07 (limited fields, no auth)
Candidacies	POST /jobs/:id/applications	worker	CAN-01
	POST /jobs/:id/offers	member (active)	CAN-02 (offer belongs to a job)
	GET /workers/me/candidacies	worker	CAN-06
	GET /businesses/:id/candidacies? job_id=&status=&origin=	member	CAN-04
	GET /candidacies/:id (+ /history)	participant	Detail incl. contact per 7.3
	POST /candidacies/:id/transition	participant	CAN-03/05/07
	POST /candidacies/:id/confirm-hire	worker	CAN-08
	POST /candidacies/:id/contact-events, POST /jobs/:id/contact-events	participant / worker	CON-02
Verification	POST /verification/phone	worker	Returns code + wa.me link
	POST /verification/identity (multipart)	worker	VER-02
	POST /verification/experience	worker	VER-04
	GET /verification, DELETE /verification/:id	worker	Status; cancel pending
Admin	GET /admin/verification-requests[?status&type], GET .../:id	admin	Queues
	GET /admin/verification-requests/:id/document	admin	60 s signed URL, audit-logged
	POST /admin/verification-requests/:id/decision	admin	VER-03
	GET /admin/businesses, POST /admin/businesses/:id/decision	admin	ADM-02
	GET /admin/users, POST /admin/users/:id/suspend, /unsuspend, /password-reset-code	admin	ADM-05
	GET /admin/jobs, POST /admin/jobs/:id/remove	admin	ADM-06

Group	Method + path	Role	Purpose
	GET /admin/reports, POST /admin/reports/:id/resolve	admin	ADM-07
	GET /admin/metrics, GET /admin/audit-logs	admin	ADM-08/09
Other	POST /reports	any	SAF-02
	GET /notifications, POST /notifications/:id/read, POST /devices	any	NTF-01/03
	GET /health, GET /version	public	Monitoring
	POST /internal/tasks/:name	secret header	Scheduled tasks, Section 12.4

Improvements over the idea document's example endpoints: offers are created under a job (/jobs/:id/offers), not under a worker, so every offer has a job context; a role-scoped candidacy list replaces separate application/offer lists; one transition endpoint enforces the state machine in a single place; /workers/me avoids passing IDs for self-actions (removing a whole class of ownership bugs).

Authorization rules (enforced in the service layer, covered by a table-driven test matrix): every mutation checks ownership (worker_id == caller or caller ∈ business_members of the resource's business); cross-tenant reads return 404 ; admin routes require role = ADMIN ; a business resource is reachable only if the business is ACTIVE (except owner's own dashboard).

12. Architecture summary

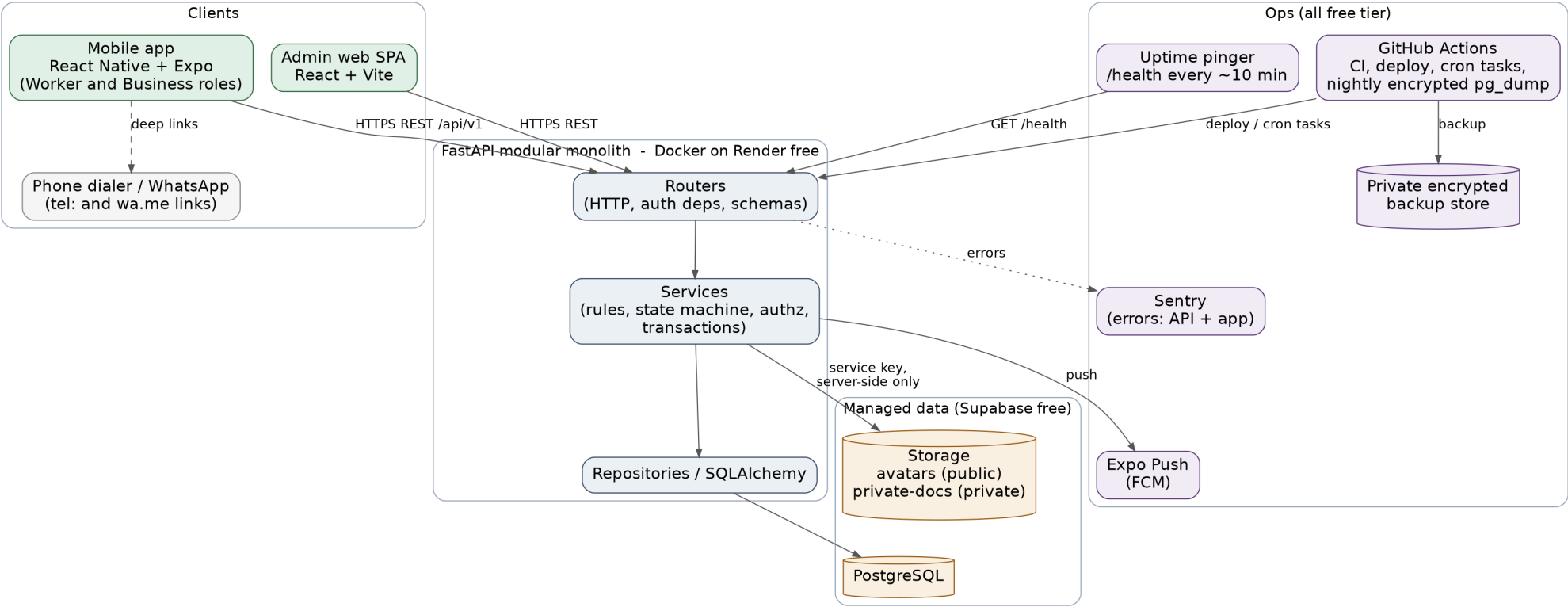
12.1 Stack decisions and why

Layer	Choice	Why	Rejected / deferred
Mobile	React Native + Expo (TypeScript), Expo Router	Team already writes React/TS; one codebase for both roles; Android-first with iOS later at low cost; free tooling (EAS)	Flutter: new language, no reuse of team skill. Native Kotlin / Swift: two codebases for a 3-person team; only justified by a hard native requirement Staffbro does not have
Mobile libs	TanStack Query (server state), React Hook Form + Zod (forms), expo-secure-store (refresh token), react-i18next, expo-image-picker + expo-image-manipulator (client-side compression), expo-notifications, Linking for tel: / wa.me	Small, well-known, no custom native modules → stays inside Expo managed workflow	Redux (overkill), offline-first sync engines
Backend	FastAPI (Python 3.12) modular monolith, Pydantic v2, SQLAlchemy 2.0, Alembic	Team knows Python; OpenAPI for free; same language as the future AI/matching work	Microservices; Node/NestJS (no advantage for this team)
Auth	Self-owned: Argon2id, JWT access 15 min, rotating refresh 30 days stored hashed	Phone-first identity; single authorisation point; no vendor lock-in	Supabase Auth (needs SMS provider for phone login), Firebase Auth (phone login needs billing)
Database	PostgreSQL on Supabase (free), extensions pg_trgm, citext	Relational marketplace data; managed; PostGIS available later	Firestore/Mongo (relational queries), self-hosted Postgres
Object storage	Supabase Storage, two buckets (avatars public, private-docs private), server-side only	Same vendor/quota as DB; signed URLs for admin	Direct-to-bucket client uploads; S3

Layer	Choice	Why	Rejected / deferred
Search	Postgres filters + <code>pg_trgm</code> + alias arrays; keyset pagination	Deterministic, explainable, zero infra	Elasticsearch/Meilisearch, vector search
Admin	React + Vite + TypeScript SPA , shadcn/ui, TanStack Table; static hosting (Cloudflare Pages / Vercel / Netlify free)	Reuses the team's React skill; 5–6 screens; talks to the same API	Django admin (second stack), Retool (cost)
Backend hosting	Docker on Render free web service (fallbacks in 12.6)	Deploy from GitHub with no card required; Docker keeps the app portable	Kubernetes, serverless functions (cold starts + DB pooling headaches)
CI/CD	GitHub Actions	Free for the repo sizes involved	Self-hosted runners
Errors / uptime	Sentry free plan (API + app), UptimeRobot-style pinger on <code>/health</code>	Free; also serves as keep-alive	Datadog etc.
Push	Expo Push Service (FCM underneath)	Free, no server infra	Self-run push, OneSignal

Modular monolith rule: modules call each other's *service* functions, never each other's tables. If a module is ever extracted (matching, messaging), the seam already exists.

12.2 System diagram



System architecture: clients, modular monolith, managed data, free-tier ops.

12.3 Code structure

Backend (vertical slices; add repository.py only where queries are non-trivial — search, candidacy lists):

```
backend/  
  app/  
    main.py  
    core/          config, db session, security (hashing/JWT), deps (current_user, require_role),  
                   errors, logging, rate limiting, pagination  
  
    modules/  
      auth/ workers/ businesses/ jobs/ candidacies/ verification/  
      admin/ catalog/ files/ notifications/ reports/  
        router.py schemas.py service.py models.py [repository.py]  
      utils/      phone normalisation, slugs, image processing  
    alembic/      forward-only migrations  
    tests/        unit (rules) + integration (real Postgres) + authz matrix  
    Dockerfile
```

Layer	Owns	Must not
Router	HTTP, auth dependencies, request/response schemas	Business rules, DB queries
Service	Business rules, state machine, authorisation, transactions	HTTP types
Repository (where present)	Complex queries, pagination	Rules
core	Cross-cutting concerns only	Domain logic

Mobile (Expo Router):

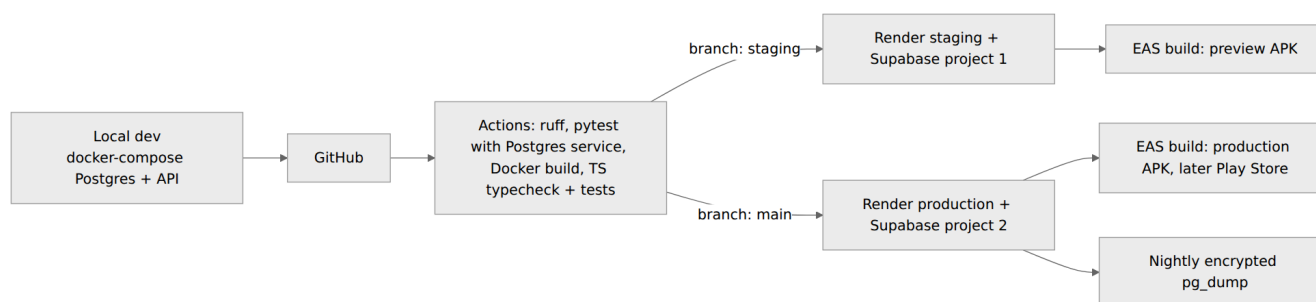
```
mobile/  
  app/          (auth)/login, register · (worker)/(tabs)/jobs, applications, profile ·  
(business)/(tabs)/dashboard, workers, jobs  
  src/  
    api/        generated client + fetch wrapper (attach token, refresh once on 401)  
    features/    auth, worker-profile, jobs, discovery, candidacies, verification, business  
    components/  shared UI kit: Button, Field, Card, Badge, EmptyState, ErrorState,  
  Skeleton  
    i18n/ hooks/ lib/ (secure-store, linking, image upload)
```

Role-based navigation: after login, role selects the (worker) or (business) route group; route guards redirect on mismatch. Loading/error/empty states are shared components, not per-screen. **Offline:** cache last-viewed lists for read-only viewing (P1); no offline write queue — mutations show a clear retry state. Low-end Android target: images ≤ ~150 KB, list virtualisation, no heavy libraries.

12.4 Scheduled tasks

Render's free tier can sleep, so in-process schedulers are unreliable. GitHub Actions cron calls POST /internal/tasks/:name (secret header): expire-candidacies (daily), expire-jobs (daily), purge-identity-docs (hourly failsafe), purge-notifications (weekly). Tasks are idempotent.

12.5 Environments, CI/CD, rollback, backups



- **Environments:** local (Docker) / staging (free Supabase project #1) / production (free project #2) — this uses exactly the two free Supabase projects. Secrets live in Render/GitHub encrypted secrets; a `.env.example` documents keys; nothing secret in the repo or the app bundle.
- **Migrations:** Alembic, **forward-only and backward-compatible** (expand → deploy → contract) so a rollback of the app never needs a schema rollback. Entrypoint runs `alembic upgrade head` under a Postgres advisory lock.
- **Rollback:** redeploy the previous Render deploy / Docker image tag; mobile hotfixes via EAS Update (JS-only) or a new APK.
- **Backups:** nightly scheduled `pg_dump` in GitHub Actions, encrypted (e.g. `age`) before leaving the runner, stored in a private location; **restore drill once before launch**. Target RPO 24 h, RTO 4 h. Backups contain PII — encryption is mandatory.
- **Mobile builds:** EAS Build (or local builds) producing an APK for sideloading during the pilot.

12.6 Free-tier facts and what happens as you grow

Figures reflect third-party and vendor pages read in September 2026 — **re-check each pricing page before committing** (Appendix B lists sources).

Service	Free-tier reality	Consequence for Staffbro	Upgrade trigger
Supabase	2 projects, 500 MB DB, 1 GB storage, 5 GB egress, pauses after 7 days idle , daily backups only on paid plans	Pilot traffic keeps it awake, but staging will pause; no built-in backup	DB > ~400 MB, storage > ~800 MB, or you need managed backups → Pro (≈ \$25/mo)
Render (web service)	Free instances sleep after ~15 min idle , ~30–60 s cold start; 750 instance-hours/month for the workspace	Prod is kept warm by the pinger (one always-on service fits within 750 h); staging must be allowed to sleep	Cold-start complaints or sustained traffic → paid instance (≈ \$7/mo, verify)
Expo EAS	~30 free builds/month (iOS share limited), OTA updates for ~1,000 monthly users; no overage — builds simply stop until reset; local builds are the escape hatch	Plenty for a 3-person team	> 1,000 OTA users or build queue pain → Starter (~\$19/mo)
GitHub Actions	Free minutes for private repos (verify current allowance)	Enough for CI + cron + backups	Heavy CI
Expo Push / FCM	Free	—	—
Play Console	One-time registration fee (~\$25; verify, and check current testing requirements for new personal accounts)	Post-pilot	Public release
Apple Developer	Annual fee	iOS deferred	Demand from iOS users
SMS OTP	Never free at realistic scale	Not used; manual confirmation instead	> ~500 workers → evaluate paid OTP or automated WhatsApp verification

Estimated cost when the free tiers run out: roughly \$30–60/month (Supabase Pro + paid Render instance + optional EAS Starter). If the team lacks an international-payment-capable card, decide this **before** pilot (open decision D8).

12.7 Mobile framework evaluation (summary)

Criterion	RN + Expo	Flutter	Kotlin	Swift
Dev speed for this team	Fastest (React/TS reuse)	Slower (Dart)	Slow	Slow
Android-first fit	Good	Good	Best	✗
Future iOS	Same codebase	Same codebase	Second app	Only iOS
Team of 3 maintenance	One codebase	One codebase	Two	Two
Free tooling / builds	EAS free + local builds	Free	Free	Needs Mac + fee
Long-term scale	Sufficient for this product type	Sufficient	Best raw performance	Best on iOS

Verdict: React Native + Expo + TypeScript. The assumption survives challenge; the real risks are distribution (APK sideload → Play Store) and low-end-device performance, both handled above.

13. Security and privacy requirements

13.1 Mandatory for MVP

Area	Control
Passwords	Argon2id; min 8 chars; breached/common-password check (P1); never logged
Tokens	Access 15 min in memory; refresh 30 d in <code>expo - secure - store</code> ; stored server-side as hashes; rotation + reuse detection
Authorisation	Role checks + ownership/membership checks in the service layer; cross-tenant reads → <code>404</code> ; automated authz matrix tests in CI (every endpoint × role)
Input validation	Pydantic schemas on every input; enum whitelists; max lengths; E.164 normalisation
SQL injection	Parameterised queries via SQLAlchemy only; no string-built SQL
Rate limiting	Per-IP and per-phone limits on auth; per-business offer/view limits; global default per IP
Transport	HTTPS only (platform-terminated TLS); HSTS on admin
CORS	Allow-list of the admin origin only; mobile needs none
Secrets	Env vars in platform secret stores; service-role key server-side only; rotate on any suspected leak
Logging	Structured JSON with request ID; never log passwords, tokens, CNIC data, full phone numbers (mask to last 3 digits) or document paths
Sensitive docs	Private bucket, backend-only access, 60-second signed URLs, every view audit-logged, deleted at decision
Admin	Seed-created accounts, stricter rate limit, all actions in <code>audit_logs</code>
Consent	ToS + privacy notice acceptance recorded; clear explanation of what the CNIC image is used for and that it is deleted
Reporting & suspension	Immediate suspension; reports queue (P1)

13.2 Can wait

TOTP 2FA for admin, automated malware scanning of uploads, WAF, field-level encryption of phone numbers, automated anomaly detection, formal penetration test, DPA/SOC-type paperwork.

13.3 File upload rules

Type	Bucket	Max upload	Allowed	Processing	Who can read
Profile photo	avatars (public, random UUID path)	5 MB	JPEG, PNG, WebP	Magic-byte check, re-encode to WebP/JPEG ≤ 512 px, strip EXIF/GPS	Anyone with the URL (shown to businesses)
CV (P2)	private-docs	5 MB	PDF	Signature check	Candidacy participants via signed URL
CNIC / selfie	private-docs	5 MB	JPEG, PNG	Signature check, re-encode, strip EXIF	Admin only, 60 s signed URL

All uploads pass through the API (never trust client MIME type), are named with server-generated UUIDs (never user filenames), and are counted against per-user upload limits.

13.4 Account deletion

Worker: delete profile PII (name, bio, photo, experience, references, phone → tombstone), delete all documents, revoke tokens, keep candidacies/status events/contact events with the worker shown as "Deleted user" so the counterpart's history and platform metrics stay intact. Business owner: business set `SUSPENDED` / `deleted_at`, open jobs closed. Backups age out within 30 days. Provide an in-app deletion path (also expected by Play Store policy — verify).

13.5 Legal context (assumption A5 — confirm with a lawyer)

As of Chambers' 2026 Pakistan guide, the Personal Data Protection Bill is still a draft that has not passed both houses of Parliament; sector rules and the Prevention of Electronic Crimes Act apply meanwhile. The draft mirrors GDPR-style principles and contains data-localisation ideas for "critical" data. The PRD therefore designs to those principles (consent, minimisation, purpose limitation, deletion) and keeps the most sensitive data (CNIC images) short-lived and out of backups where possible.

14. Product metrics and instrumentation

All metrics derive from existing tables — no analytics vendor in MVP; the admin dashboard reads SQL views.

Metric	Definition	Source	Pilot target (hypothesis)
Registered / complete / phone-confirmed / ID-verified workers	Counts; complete = completeness ≥ 80 %	worker_profiles	400 / 250 / 150 / 75
Approved businesses; weekly active businesses	ACTIVE ; ≥ 1 job post or candidacy action in 7 days	businesses , events	25; ≥ 60 % of approved
Jobs posted	Count by week	jobs	≥ 60 in 8 weeks
Applications per job (72 h)	Median candidacies per job within 72 h	candidacies	≥ 5
Time to first candidate	Job created → first candidacy created	jobs , candidacies	≤ 24 h median
Business response rate	Candidacies with a status change ≤ 72 h	status events	≥ 60 %
Worker offer response rate	OFFERED → ACCEPTED / DECLINED ≤ 72 h	status events	≥ 40 %
Contact rate	Candidacies with ≥ 1 contact event	contact_events	≥ 50 %
Interview rate	Candidacies reaching INTERVIEW	status events	≥ 15 %

Metric	Definition	Source	Pilot target (hypothesis)
Confirmed hire rate	Closed jobs with ≥ 1 worker-confirmed hire	candidacies	$\geq 30\%$
Time to hire	Job created $\rightarrow$ first HIRED	jobs , events	≤ 7 days median
Repeat business usage	Businesses posting a 2nd job ≤ 30 days	jobs	$\geq 40\%$
Verification turnaround	Request $\rightarrow$ decision	verification_requests	≤ 24 h

What proves product-market fit (in priority order): (1) repeat business usage together with worker-confirmed hires that happened without founder prodding; (2) time-to-first-candidate beating the businesses' current method; (3) response rates on both sides; (4) verification take-up (do people value the badges?). Registration counts are vanity metrics — report them, don't optimise them. Complement numbers with 10–15 structured interviews with businesses (would they be very disappointed if Staffbro disappeared?).

Measurement honesty: contact happens off-platform, so hire outcomes rely on business status updates plus worker confirmation (CAN-08) and nudges (CAN-10). Report "unconfirmed hires" separately.

15. Non-functional requirements

Area	MVP target
Performance	API p95 < 500 ms for list/detail when warm; cold start masked by keep-alive and a "waking up" state in the app; app cold start < 4 s on a low-end Android; image payloads $\leq \sim 150$ KB
Capacity	1,000 registered users, ≤ 50 concurrent, DB < 400 MB before action
Availability	Best-effort $\approx 99\%$ monthly during the pilot (free tiers, no SLA); RPO 24 h, RTO 4 h
Security	Section 13.1 all met before launch
Scalability	$\sim 10\times$ headroom by paying for larger instances only; no rewrite: stateless API, all state in Postgres/Storage
Maintainability	Modular monolith, lint + type checks in CI, migrations in Git, authz matrix + state-machine unit tests, OpenAPI-generated client
Accessibility	Font-scaling support, contrast $\geq 4.5:1$, tap targets ≥ 48 dp, icon + text labels, plain language, no information conveyed by colour alone
Localisation	English at launch; all strings externalised; Urdu (RTL) P1; catalogue aliases include Roman Urdu; dates/currency formatting via locale (PKR, no decimals)
Compatibility	Android 8+ (assumption A4), 4-inch to large screens, unreliable 3G/4G

16. Release plan

Assumption: each of the three works $\approx 15\text{--}20$ h/week $\rightarrow \approx$ **11 weeks to pilot-ready**, then an 8-week live pilot. Adjust after Phase 0.

Phase	Weeks	Features	Database	API	Mobile / admin	Testing	Definition of done
0 Architecture + UX	1	Finalise this PRD, decisions D1–D8; low-fi wireframes of ~15 core screens; seed data lists	Seed: professions, skills (with Roman Urdu aliases), Islamabad/Rawalpindi areas	OpenAPI skeleton + error envelope	Expo + Vite projects, CI, UI kit basics	—	PRD signed off; wireframes tested with 3 workers + 3 businesses; repos, CI, staging deploy of "hello /health" working
1 Auth + profiles	2	AUTH-01..07, WRK-01..06, BIZ-01/03/05	users , refresh_tokens , catalogue tables , worker_profiles , worker_skills , worker_experience , businesses , business_members , audit_logs	Auth, /me , catalogue, worker & business profile endpoints, photo upload	Onboarding, role routing, worker profile forms, business creation	Unit: phone normalisation, hashing; integration: auth + ownership; authz matrix v1	Register/login/refresh work on a real phone; Worker A cannot edit Worker B; photo upload safe
2 Jobs + admin shell	2	JOB-01..06, 08; ADM-01/02/03/05/09	jobs , job_skills , saved_* , verification_requests (PHONE)	Jobs CRUD/search, admin business + phone queues	Job list/filter/detail, post/edit/close (business), admin web shell	Search filter tests; Business A cannot edit Business B's job; pending business blocked	Approved business posts a job that a worker finds via Roman-Urdu keyword; admin approves in < 2 min
3 Candidacies (Flow A)	2	CAN-01,04..08 (application side), CON-01..03, CAN-08	candidacies , candidacy_status_events , contact_events	Apply, list, transition, contact events, confirm-hire	Apply, "My applications" timeline, business applicant list, contact buttons	State-machine exhaustive tests; duplicate apply; contact-reveal tests	Full apply $\rightarrow$ shortlist $\rightarrow$ contact $\rightarrow$ hire $\rightarrow$ confirm path works on 2 devices
4 Discovery + offers (Flow B)	1.5	DSC-01..05, CAN-02/03, WRK-07	Indexes for search; search_events , profile_view_events	Worker search, profile view, offers	Worker search UI + filters, offer composer (inline job), offer response	Rate-limit tests; phone never in list payload (automated assertion)	Business finds a worker, sends offer, worker accepts, phone revealed only then
5 Verification	1.5	VER-01..05 (+06/07 if time)	worker_documents , worker_identity_hashes , doc purge task	Phone/ID submit, admin document URL + decision	Verification screens, badges; admin ID queue	Signed-URL expiry; image deleted at decision; upload abuse tests	End-to-end ID verification with deletion proven; badges visible on cards
6 Admin + polish	1	ADM-06..08, SAF-02, NTF-01..03 (push + inbox), JOB-07 share link	reports , notifications , push_tokens	Reports, metrics views, notifications	Admin jobs/reports/metrics; push wiring; share landing page	Push failure tolerance; metrics query checks	Founders can run the pilot from the admin panel alone
7 Deploy + test	1.5	Hardening, backups, monitoring, ToS/privacy copy, Urdu strings (if D3), APK distribution	Backup + restore drill	Rate limits tuned; /internal/tasks cron	Signed release APK; crash reporting	Pilot dry-run with 5 businesses / 30 workers; low-end phone test; restore drill	All P0 done, Section 13.1 checklist green, no critical bugs open, backup restore proven

Cut-line rule: if a phase slips, drop P1 items in this order: nudges (CAN-10) $\rightarrow$ saved items $\rightarrow$ push $\rightarrow$ Urdu UI $\rightarrow$ share link (last, because it is the growth lever).

17. Team responsibilities

Person	Primary ownership	Also
Muhammad Haris	Backend core: DB schema, auth, candidacies + state machine, storage, deployment, CI/CD, backups, security	Architecture decisions, API contract (OpenAPI), code review
Farhan Manzoor	Mobile app: shell, worker flows, shared UI kit, forms, i18n	API integration tests, QA pass on devices
Khizar Sheikh	Domain and operations: profession/skill taxonomy + Roman Urdu aliases, pilot recruiting of businesses and workers, admin verification operations, UAT scripts, ToS wording input	Assumption A6: if Khizar is also a full-stack developer, he takes business-side mobile screens and the admin web app; if not, Haris/Farhan split those

Working agreements: contract-first (OpenAPI change → generated client → both sides implement); `main` protected, PR review by one other person; ≤ 2-day-old branches; each PRD requirement ID becomes one or more GitHub issues labelled with phase and priority.

18. What not to build now — and how the MVP grows

Excluded from MVP	Why it waits	Hook already in the MVP
AI candidate matching	No outcome data yet; deterministic search is explainable and enough for a few hundred workers	Structured skills/requirements, <code>candidacy_status_events</code> , search/view events; a future <code>matching</code> module scores (<code>job</code> , <code>worker</code>) and only changes ranking in <code>GET /workers</code>
In-app chat	Doubles scope; WhatsApp already used	<code>candidacy_id</code> as conversation key; add <code>messages</code> table + push
Recommendation engine, advanced analytics	Nothing to learn from yet	Event tables + SQL views
Microservices, Kubernetes, event streaming	Three engineers, ~hundreds of users	Module boundaries; extract only when a module has different scaling needs
Payments, subscriptions, payroll	Unproven willingness to pay; adds compliance	Business <code>plan</code> column can be added later; candidacy <code>HIRED</code> events show value delivered
Automated KYC / OCR	Cost and vendor risk before demand is proven	<code>verification_requests</code> abstracts "who decided": manual admin now, provider webhook later
Complex notifications (SMS/email/WhatsApp API)	Cost	<code>notifications</code> table + one dispatcher function
Ratings, reputation, interview scheduling	Needs hire volume	<code>HIRED / REJECTED</code> events + <code>worker_confirmed_hire_at</code> feed reputation later
Multi-city / nationwide	Prove one metro first	<code>locations</code> tree already national; add areas by seed
Excessive DevOps	Time sink	Docker + Actions + one platform

Later roadmap (indicative): automated phone confirmation via WhatsApp inbound webhook → OTP if worth the cost → Play Store + business web dashboard → in-app messaging → ratings/reputation → premium business plans → matching/ranking → multi-city.

19. Risks and mitigations

#	Risk	Impact	Mitigation
R1	Two-sided cold start	No supply/demand meets	Khizar seeds 25 businesses first; businesses invite their own candidates via shared links; assisted onboarding sessions
R2	Off-platform leakage (contact → hire unseen)	Metrics blind, no revenue path later	Contact-tap logging, nudges, worker-confirmed hire; deliver value beyond contact (verification, reach, pipeline)
R3	Scam/fake jobs; fee-charging	Worker harm, brand damage	Business approval gate, reports, ToS "no fees", fast suspension
R4	Impersonation without OTP	Wrong person contacted	Discoverability requires phone confirmation; badge shown; admin review
R5	CNIC leak	Legal + trust catastrophe	Minimisation, deletion at decision, private bucket, audit logs, no CNIC in backups where avoidable
R6	Free-tier fragility	Downtime, data-loss fear	Keep-alive, encrypted backups + restore drill, budget line of ~\$30-60/mo when needed
R7	Manual ops overload	Slow verification → churn	Cap pilot cohort, batch review windows, 24 h SLA, automate phone confirmation first
R8	Low digital literacy	Drop-off in onboarding	Icon-led UI, short forms, Urdu, assisted onboarding, profile can be created by Khizar's team on the worker's behalf (future option)
R9	Team capacity (3 part-timers, 2 clients)	Schedule slip	Contract-first, cut-line rule, no P2 work before pilot
R10	Legal/regulatory uncertainty	Late compliance cost	Lawyer review of ToS/privacy; data-minimisation by design; confirm whether any licence applies to running a job platform
R11	Supabase region latency/data residency	Slower calls; future localisation rules	Choose the closest region (likely Mumbai/Singapore); keep sensitive data short-lived; DB portability
R12	Google Play policy friction	Delayed public release	Pilot via APK; read current Play requirements early

20. Assumptions and open decisions

Assumptions - A1 Pilot is Android-only; workers and business managers both have smartphones with WhatsApp. - A2 Businesses are willing to be phoned and approved manually before posting. - A3 All money is in PKR; pay is monthly or daily; no currency handling. - A4 Minimum Android 8; Expo SDK current at build time. - A5 No enacted comprehensive data-protection law applies yet (Section 13.5) — to be confirmed with a lawyer. - A6 Khizar Sheikh's role is domain/operations with possible full-stack ability (idea document was ambiguous). - A7 One admin-operated WhatsApp Business number exists for phone confirmation. - A8 Team availability ≈ 15–20 h/week each.

Open decisions (owner → needed by)

#	Decision	Recommendation	Owner → phase
D0	Product name	Confirmed: Staffbro (the earlier idea document called it "Get")	Founders → done
D1	Business types: only restaurant/hotel/grocery, or an OTHER type (cafés, bakeries, caterers)?	Add OTHER if pilot interviews show demand	Khizar → 0
D2	Discovery privacy: first name + last initial until candidacy (this PRD) vs. full names	Keep initials	Founders → 0
D3	Urdu RTL UI in the pilot or English + iconography only	Ship Urdu if Farhan has capacity in Phase 7; otherwise post-pilot	Founders → 1

#	Decision	Recommendation	Owner → phase
D4	Store CNIC HMAC for duplicate detection?	Yes, with legal sign-off	Founders + lawyer → 5
D5	Domain name for share links, Android App Links, admin URL	Buy a .pk / .com domain (small cost) or use custom URL scheme + landing page	Haris → 2
D6	Who staffs admin queues and the WhatsApp number; SLA	Two named founders, 24 h SLA	Founders → 2
D7	Profession/skill/area seed lists (≈ 8 professions, 60–100 skills, key areas)	Khizar drafts, Farhan/Haris import	Khizar → 0
D8	Does the team have a card that works for international payments (decides hosting fallbacks, Play Console)?	Confirm now	Haris → 0
D9	Do workers pay anything, ever? Do businesses?	Free for both in pilot; test willingness-to-pay in interviews	Founders → pilot
D10	Legal review of ToS/privacy and any licensing question	Book a one-off lawyer session before launch	Founders → 6

Appendix A — Glossary

Candidacy one worker ↔ one job, created by application or offer. **Direct offer** business-initiated candidacy.

Discoverable a worker profile visible in business search. **Reverse OTP** proving phone ownership by having the user send a code to Staffbro's WhatsApp number. **Keyset pagination** cursor based on sort keys rather than page offsets.

Modular monolith one deployable app with strict internal module boundaries. **HMAC** keyed hash; here used so a CNIC number can be compared without being stored. **EAS** Expo Application Services (build/update). **RLS** Postgres row-level security (deliberately not used). **NIC** the incubator whose mentors will read this document.

Appendix B — Sources for free-tier facts (read September 2026; verify before relying)

- Supabase free-tier limits: jetadmin.io "Supabase Pricing 2026 guide"; automationatlas.io "Supabase free tier limits 2026"; cloudzero.com "Supabase pricing".
- Render free-tier sleep behaviour: render.com "Platforms with a real free tier for developers in 2026".
- Firebase phone auth requires billing and charges per SMS: Logto "Firebase Authentication pricing" (2026).
- Expo EAS free plan: docs.expo.dev "Billing plans" and "Billing FAQ"; expo.dev changelog (free-plan limits).
- Pakistan data-protection status: Chambers "Data Protection & Privacy 2026 — Pakistan".

Appendix C — Implementation notes for the backend

- Use SQLAlchemy async + `asyncpg` against Supabase's **pooled** connection string; disable prepared-statement caching when using the transaction pooler; keep Uvicorn to one worker on a 512 MB instance.
- Health endpoint checks the DB with a trivial query; the pinger hits it every ~10 minutes.
- Keep `pg_trgm` GIN indexes on job titles and alias arrays; test filter combinations with `EXPLAIN` on ≥ 10k seeded rows.
- Rate limiting in-process (e.g. `slowapi`) is acceptable at one instance; move to Redis only when scaling horizontally.
- Generate the TypeScript client in CI and fail the build if the committed client is stale.